

Re: Submission 6933 — response to camera-ready reviews

We thank the reviewers for careful, constructive reports. Review 1’s detailed reading in particular improved the camera-ready version. Below we explain what changed and, where we did not change the paper, why. All section references are to the camera-ready manuscript.

Text changes in this pass (minor, no results affected)

1. Defined TP/TN at first use in the contributions list.
2. Expanded IDOR, LOC, and KMS at first use.
3. Stated the model family explicitly in Experimental Setup: Sonnet (Anthropic Claude), Haiku (same model family).
4. No numeric claim was altered.

Review 1 (weak accept)

Privacy validation is security-heavy. Agreed, and this asymmetry was already stated in four places; we kept each statement and sharpened the conclusion. The abstract, the CVE-probe description, Limitations, and the Conclusion all say the probe is security-only and privacy validation is synthetic because privacy defects rarely receive CVEs. Building a real privacy corpus (annotated repositories, privacy commits, enforcement-to-code traces) is future work, stated as the main open problem in the Conclusion. We did not add a new corpus in camera-ready because it would be a new study, not a revision.

Suppression semantics vs GDPR compliance. The paper already frames findings as code-level risk signals, never compliance determinations: GDPR articles are “reporting vocabulary” and “explanatory metadata only” (Scope), categories “produce code-level risk signals only,” and R5 requires reviewer confirmation of unseen deployment context (key rotation, aggregation thresholds, vault boundaries). Pseudonymized data remaining personal data under Art. 4(5) is stated at the salted-hash example. We kept this framing prominent throughout rather than softening it.

Single model family. Acknowledged as a limitation in the paper: Sonnet and Haiku vary capacity but not provider family, so scaffold benefits need re-testing on other families. The Setup now names Anthropic Claude explicitly. New-family experiments are future work.

Semgrep comparison. The comparison is already hedged everywhere it appears: “under one generic ruleset,” “not a universal SAST result,” with advisory-specific rules and CodeQL named as stronger baselines in Discussion. We report the stated configuration (OSS `p/security-audit` + `p/owasp-top-ten`, 690 rules) and family matching precisely so readers can see what the 0.02 vs 0.53–0.61 gap does and does not mean. No change beyond the existing caveats, which we consider sufficient.

Localization prominence. File-level 0.58 vs localized 0.31 now appears in the abstract, Table 3, the CVE results text, and the Conclusion (“lower localized detection (0.31) marking the main actionability gap”).

Post-patch noise proxy. The caption, Setup, and Limitations all state the fixed-file count is a residual-noise proxy, not a false-positive rate, since fixed files may carry unrelated weaknesses. The 25/25 hand-adjudication is reported as metric validation, not as a second full audit. Expanding adjudication is future work.

Benchmark scale. Stated as limits: 128 self-contained Python files, a 12-case mechanism test whose $N=5$ runs measure run-to-run stability rather than population generality, and reporting scope (held-out and cross-surface report $N=5$ means; per-category and failure modes are single-run). No change; the paper already refuses the broader reading.

Unification framing. The paper already claims only an operational edge (one pass, half the API cost, matched F_1 /recall) plus the cross-referenced finding artifact, with “no quality win over two skills” stated. No change.

Review 2 (weak accept)

Untrusted inputs not traced through the work. The thread is: Scope defines the trust boundary (application configuration untrusted, OS environment trusted); Phase 1 maps it per change; R1 requires a concrete input-to-sink path and R4 exempts environment reads; near-miss and held-out TNs test exactly these boundaries, including the stably-wrong decorator case called out in Discussion. No text change; the chain was already present.

GDPR-specific adversary. GDPR/CCPA are used only as article-level reporting hooks, stated in Scope and per category, with policies and governance explicitly out of scope. Findings are risk signals. No change.

Collection-point assurance level. Scope states the detector traces only code-visible collection points and treats upstream outputs per the visible trust boundary; Phase 2 is labeled review-grade local reconstruction, not whole-program proof; Discussion lists no cross-file memory and no runtime verification as hard limits. No change.

Review 3 (reject)

Abbreviations. Fixed: TP/TN, IDOR, LOC, KMS expanded at first use. Remaining abbreviations (SAST, CWE, GDPR, CCPA, ORM, SSRF, XSS) are expanded at first use already.

Table 1 caption. The caption already defines the Adequate/Sec/Priv columns, notes rows cover all 30 implemented categories rather than only the unification subset, and defines the stored-XSS alias with its source. We consider it complete.

Threat-model section placement. Kept as its own section. It carries the unification boundary (in-scope injection and leakage classes vs excluded logic/runtime classes) on which the framework, the CVE split, and the limitations all depend; Review 1 endorsed this scoping. Moving it would scatter the contract.

Claude-only not stated. Now stated in Setup (Sonnet, Anthropic Claude; Haiku, same family) in addition to the model named in the LLM-usage statement and Limitations.

CVE filtering unstated. The ingestion criteria are in the Real-CVE probe section: reviewed advisories only, CWE mapped to a canonical category, linked public fix commit touching a non-generated in-scope file, anchorable hunks, with documented discards and recorded CVE/GHSA/repo/SHA provenance. No change.

Small N, one family. Acknowledged in Limitations and Conclusion (128 synthetic files, 12-case mechanism test, 8 cross-domain cases, one provider family). Larger corpora and multi-family backbones are listed as the next experiments.

References use et al. This follows Springer LNCS convention for long author lists; expanding all 45 entries would cost pages against the 20-page limit (we stand at 19). We will follow the chairs' instruction if they prefer full lists.

Simpler problem setting plus diagram. The Introduction and Scope were already rewritten in plain language in revision. We did not add a figure: at 19 pages there is no room without cutting evaluation content, and the five-phase pipeline is described step by step in the Framework section.

We believe the manuscript now answers every actionable camera-ready point within the page limit, with numerical claims unchanged and verified consistent throughout.